ETHICAL HACKING REPORT

Name: Emmanuel Sunday Ayodimeji
Task Title: Ethical Hacking
Pseudo Organization: Tes Tech

Introduction

As part of my cybersecurity internship program, I participated in an Ethical Hacking Sprint designed to simulate real-world penetration testing activities. The primary goal of this sprint was to identify and exploit vulnerabilities on a target system to gain superuser access, under defined scope and terms.

The designated target environment for this sprint included:

- **Target Website**: http://electron-store.fezzant.com:3000/#/
- **Target IP Address**: 138.68.170.157

This engagement provided an opportunity to apply both individual and team-based penetration testing skills, focusing on reconnaissance, enumeration, vulnerability analysis, and exploitation attempts.

Summary of Key Tasks

1. Reconnaissance and Information Gathering

- Independently used tools such as Nmap to scan the target IP (138.68.170.157) and identify open ports.
- Verified that ports 21 (FTP), 587 (submission/SMTP), and 3000 (web service) were active.
- As a team, we confirmed that the web application running on port 3000 was based on the OWASP Juice Shop platform, customized as an online electronics store.

2. Service Enumeration

- Attempted to interact with the FTP service but encountered timeouts, showing that the service was not accessible for exploitation.
- Conducted banner grabbing and basic HTTP header analysis to gather version information and security controls.

3. Directory and Web Application Enumeration

- Collaborated with my teammates to run Gobuster and discovered hidden directories such as /ftp and /metrics.
- Verified that sensitive data exposure was possible through misconfigured directories and files.

- Independently explored JavaScript files loaded by the application to check for hints of API endpoints.

4. Vulnerability Testing

- Worked with the team to test for and exploit multiple vulnerabilities, including:
    - SQL Injection in login and search functions (e.g., ' OR '1'='1-- for authentication bypass).
    - Cross-Site Scripting (XSS) via the search bar, which allowed script injection.
    - Server-Side Template Injection (SSTI) leading to Remote Code Execution (RCE) with root privileges.
    - Weak Password Policy that accepted trivial credentials like “12345” and “password”.
    - Insecure Direct Object Reference (IDOR) and Broken Object Level Authorization (BOLA) in shopping cart functionality.

5. Documentation and Collaboration

- I maintained notes on the tools and payloads I used, especially during reconnaissance.
- I ollaborated with the team to consolidate findings, confirm vulnerabilities, and propose remediation strategies.
- Shared knowledge of tool usage (Nmap, Gobuster, Nikto, Burp Suite) with teammates to improve efficiency.

Lessons Learned

- **Reconnaissance is critical**: Thorough scanning and enumeration revealed misconfigurations and hidden endpoints that would otherwise have gone unnoticed.
- **Teamwork matters**: By sharing payloads and testing approaches, we were able to discover more vulnerabilities than I could have alone.
- **Tool mastery improves speed and accuracy**: I gained practical skills with Nmap**,** Gobuster, Burp Suite, Nikto, and Netcat, making me more confident in real penetration testing workflows.
- **Not all ports are useful entry points**: While FTP was open, it was ultimately a dead end. The real vulnerabilities were in the web application.
- **Exploitation often comes from chaining flaws**: For example, combining weak password policy with SQL injection and SSTI led to full compromise.

Conclusion

This ethical hacking sprint was a valuable opportunity to apply both individual and collaborative penetration testing skills in a structured environment. By targeting the Electron Store web application (IP: 138.68.170.157), I was able to practice reconnaissance, enumeration, vulnerability exploitation, and documentation.

Individually, I became more proficient with reconnaissance and service enumeration. As a team, we successfully identified and exploited several critical vulnerabilities, including SQL Injection, Cross-Site Scripting, Server-Side Template Injection, and IDOR/BOLA flaws**.**

This experience has significantly enhanced my understanding of penetration testing methodologies and my ability to use industry-standard tools. It reinforced the importance of teamwork, persistence, and structured reporting in real-world cybersecurity engagements.